LRN HIPAA Compliance Checklist

Oct 27, 2026 · @jameel

Each row is one HIPAA safeguard mapped to a concrete change in an LRN project. Work P1 rows first, and set Status as you go.

- **P1:** active exposure risk; fix within 30 days.
- **P2:** needed for a defensible audit; fix within 90 days.
- **P3:** hardening toward the proposed rule; fix within 6 months.

Scope:

- LRN.MasterFileProcessorWorker (LRN.ReportEngine)
- LRN.ReportsApi
- LabMetricsDashboard (MVC)
- LRN.ARWorkbench (React)
- The shared Azure VM and SQL MI hosting

The Security Rule overhaul proposed in December 2024 is not final; its target for final action is July 2027. This checklist treats encryption and MFA as required anyway, because the proposal mandates them and OCR already expects them.

1. Cross-cutting (all projects)

These controls apply once and cover all four projects. CC-01, CC-05, CC-08, CC-15 and CC-18 carry the most breach risk today.

ID	Concern	Solution	Priority	Status
CC-01	Documented risk analysis	Run a risk analysis built on the PHI data-flow map. Refresh it yearly and after any major change.	P1	Not started
CC-02	PHI inventory	Map every place PHI rests or passes: SharePoint → MasterFileProcessor → per-lab DBs → ReportsApi → Metrics app / ARWB, plus Blob, exports and logs.	P1	Not started

ID	Concern	Solution	Priority	Status
CC-03	Business Associate Agreements	Confirm the Microsoft BAA covers SQL MI, Blob, Key Vault, Log Analytics, the VM, SharePoint and Azure OpenAI. Put a subcontractor BAA in place for DBiz.ai. Send no PHI to any vendor without a BAA.	P1	Not started
CC-04	Offshore workforce access	Record Singapore-based access in the risk analysis. Allow production access only through Bastion or VPN with MFA.	P2	Not started
CC-05	Real PHI in dev, test or GitHub	Use synthetic or de-identified data sets. Keep production files off laptops. Turn on secret and PHI scanning for the repos.	P1	Not started
CC-06	Encryption at rest (SQL)	Verify TDE on LRNMaster, Certus_LRN and every per-lab DB. Encrypt backups.	P1	Not started
CC-07	Highly sensitive columns	Apply Always Encrypted or Dynamic Data Masking to SSN, member ID and DOB.	P2	Not started
CC-08	Encryption in transit (SQL)	Set `Encrypt=True;TrustServerCertificate=False` in every connection string held in Key Vault.	P1	Not started
CC-09	Encryption in transit (web)	Allow TLS 1.2+ only and disable TLS 1.0/1.1 on IIS. Add an HTTPS redirect and HSTS.	P1	Not started
CC-10	Secrets management	Hold all secrets in kv-lrnmetrics-prod, never in appsettings, repos or images. Rotate them on a schedule.	P1	Not started
CC-11	User authentication	Use Entra ID SSO, with a Conditional Access policy requiring MFA for both web apps.	P1	Not started
CC-12	Service identities	Use managed identity or gMSA for SQL, Blob and Key Vault, and retire SQL passwords.	P2	Not started
CC-13	Unique user IDs	Remove shared and generic logins so each person has one account.	P1	Not started
CC-14	Access reviews	Review roles and lab assignments quarterly. Deprovision within 24 hours of an exit.	P2	Not started
CC-15	Lab (tenant) isolation	Check lab scope server-side on every query path. Add integration tests that try cross-lab access.	P1	Not started
CC-16	Database audit trail	Send SQL Auditing to Log Analytics and immutable storage, with 6-year retention.	P2	Not started

ID	Concern	Solution	Priority	Status
CC-17	Application audit trail	Add a shared PhiAccessAudit table recording user, lab, record or report, action, time and IP.	P1	Not started
CC-18	PHI leaking into logs	Log IDs only. Scrub LRN_Error_Log, Serilog, IIS and App Insights.	P1	Not started
CC-19	Vulnerability scanning	Turn on Defender for Cloud for the VM, SQL, Storage and containers. Scan at least every 6 months.	P2	Not started
CC-20	Penetration testing	Run an external pen test of the web apps and API every year.	P3	Not started
CC-21	Contingency plan	Keep backups and run a tested restore. Document RTO and RPO.	P2	Not started
CC-22	Incident response	Write a runbook naming who decides on breach status, and track the 60-day notification clock.	P2	Not started
CC-23	Workforce training	Give annual HIPAA training to everyone with production access.	P3	Not started

2. LRN.MasterFileProcessorWorker (LRN.ReportEngine)

The biggest risk here is a file misrouted into the wrong lab's database (MF-05), followed by PHI left behind in temp CSVs and error logs.

ID	Concern	Solution	Priority	Status
MF-01	SharePoint access scope	Use an app registration with `Sites.Selected` limited to the week-folder site, not `Sites.Read.All`. Store its certificate in Key Vault.	P1	Not started
MF-02	Temp CSVs on disk	Stream rows straight into SqlBulkCopy where possible. Otherwise write to one ACL-restricted folder on an encrypted disk.	P1	Not started

ID	Concern	Solution	Priority	Status
MF-03	Temp file cleanup	Delete temp files in a `finally` block. Add a scheduled sweep for orphaned files older than 24 hours.	P1	Not started
MF-04	Bulk copy connection	Use an encrypted SqlBulkCopy connection under a managed identity or gMSA. Never use `sa` or shared logins.	P1	Not started
MF-05	Cross-lab misrouting	Before loading, check that the file's lab (from the LabMappings JSON) matches the target DB. Fail the run and log to LRN_Error_Log on a mismatch.	P1	Not started
MF-06	Staging tables hold PHI	Give the `_Staging` tables the same permissions as the live tables, and truncate them after each swap.	P2	Not started
MF-07	PHI in step and error logs	Log FileLogId, RunId, row number, column and error type in LRN_Error_Log and LRN_Step_Log. Never log row values.	P1	Not started
MF-08	PHI in file paths and names	Check that SourceFullPath and FileName never carry patient identifiers. Reject or rename files that do.	P2	Not started
MF-09	RowHash misuse	Use SHA-256 for change detection only. Never treat the hash as de-identification.	P3	Not started
MF-10	Five-week snapshots in Blob	Use a private container with a lifecycle rule deleting after 5 weeks, soft delete and GUID blob names. Read snapshots only through the API, with auditing.	P2	Not started

ID	Concern	Solution	Priority	Status
MF-11	Service run account	Run the worker under a gMSA or low-privilege account, never LocalSystem or an admin.	P2	Not started
MF-12	Load integrity	Record row counts and file checksums per RunId in ReportRunIdInfoLog. Alert on mismatches.	P2	Not started
MF-13	Retention of old weekly loads	Keep only the current week in the DB, as you planned. Document the purge, and remember that SQL backups still hold earlier weeks.	P3	Not started

3. LRN.ReportsApi

The API is the gate to every lab's PHI, so lab-level authorization (API-04) and the access audit trail (API-07) come first. The Blob upload rows (API-14 to API-20) cover the AR Workbench document storage work.

ID	Concern	Solution	Priority	Status
API-01	JWT validation	Validate issuer, audience, lifetime and signature, with signing keys from Key Vault. Keep access tokens to 15 to 60 minutes.	P1	Not started
API-02	ExternalApiClients secrets	Confirm SecretHash uses PBKDF2 or bcrypt, keep the lockout, and rotate the ETL client secret yearly. Plan a move to Entra client credentials.	P1	Not started

ID	Concern	Solution	Priority	Status
API-03	Endpoint authorization	Put `[Authorize]` with a role or policy on every controller. Add an explicit `[AllowAnonymous]` allow-list covering health checks only.	P1	Not started
API-04	Lab-level authorization (IDOR)	Never trust a labId from the request. Resolve the allowed labs from the caller's claims in a shared filter, and return 403 otherwise.	P1	Not started
API-05	PHI in URLs	Move patient name, MRN and member-ID searches to POST bodies or opaque IDs, because IIS logs keep query strings.	P1	Not started
API-06	Minimum necessary	Return DTOs with only the fields each screen needs, never EF entities.	P2	Not started
API-07	Access audit trail	Add middleware that writes to PhiAccessAudit: user or client, lab, endpoint, record IDs, outcome, time and IP.	P1	Not started
API-08	Response caching	Send `Cache-Control: no-store` and `Pragma: no-cache` on every PHI response.	P2	Not started
API-09	Error leakage	Return ProblemDetails with no stack traces or SQL text in production, and log the full error server-side without PHI.	P1	Not started
API-10	CORS	Allow only the AR Workbench and Metrics app origins, never `*`.	P1	Not started

ID	Concern	Solution	Priority	Status
API-11	Swagger exposure	Disable Swagger UI in production, or put it behind auth.	P1	Not started
API-12	Abuse and brute force	Add ASP.NET rate limiting per client and IP, and validate input on every model.	P2	Not started
API-13	SQL injection	Use parameterized queries only, including inside stored procedures that build dynamic SQL.	P1	Not started
API-14	Blob container exposure	Disable public access on the storage account and container, and reach it through a private endpoint.	P1	Not started
API-15	Upload and download tokens	Issue user-delegation SAS scoped to one blob, read or write only, expiring in 5 to 15 minutes. Never use account-key SAS.	P1	Not started
API-16	Malicious files	Validate file type by magic bytes and enforce a size limit. Turn on Defender for Storage malware scanning.	P1	Not started
API-17	PHI in blob names	Name blobs by GUID and keep the original filename and metadata in SQL.	P1	Not started
API-18	Document integrity and recovery	Turn on blob versioning and soft delete, and store a SHA-256 hash with each upload.	P2	Not started
API-19	Document audit	Write an audit row for each upload, view, download and delete, with user, lab and claim.	P1	Not started

ID	Concern	Solution	Priority	Status
API-20	Document retention	Add a lifecycle policy that follows the client's record retention period, set by compliance.	P3	Not started

4. Metrics web app (LabMetricsDashboard, ASP.NET MVC)

Exports are the largest leak path in this app (WEB-06 to WEB-08), and the dynamic menu needs to become real server-side authorization rather than hidden links (WEB-04).

ID	Concern	Solution	Priority	Status
WEB-01	Sign-in	Use OpenID Connect with Entra ID and MFA through Conditional Access, and remove any local username/password login.	P1	Not started
WEB-02	Automatic logoff	Set a 15-minute sliding idle timeout and an 8-hour absolute session limit, with a warning dialog before logout.	P1	Not started
WEB-03	Cookie security	Mark auth cookies `Secure`, `HttpOnly` and `SameSite=Lax` or `Strict`.	P1	Not started
WEB-04	Role-based menu used as access control	Put `[Authorize(Policy=...)]` on every controller action, driven by the same role-menu tables. A hidden menu item is not a control.	P1	Not started
WEB-05	Lab scoping in data access	Apply the shared lab-scope check in the repository or stored-procedure layer, and pass the user's allowed labs on every call.	P1	Not started
WEB-06	Export authorization	Add a separate Export permission per role covering Excel, CSV, PPT (CBOE) and PDF.	P1	Not started

ID	Concern	Solution	Priority	Status
WEB-07	Export audit	Log every export to PhiAccessAudit with user, report, lab, filters and row count.	P1	Not started
WEB-08	Export content	Drop identifiers the report doesn't need. Add a footer with user, date and a confidentiality note.	P2	Not started
WEB-09	Identifiers on screen	Mask patient identifiers in grids by default, with an audited reveal action for authorized roles.	P2	Not started
WEB-10	CSRF	Use `[ValidateAntiForgeryToken]` on all POST, PUT and DELETE actions, or a global filter.	P1	Not started
WEB-11	Security headers	Add CSP, HSTS, `X-Content-Type-Options: nosniff`, `frame-ancestors 'none'` and `Referrer-Policy: no-referrer`.	P2	Not started
WEB-12	Error pages	Show a custom error page in production with no developer exception page and no stack traces.	P1	Not started
WEB-13	Browser caching of PHI pages	Send `Cache-Control: no-store` on report and patient pages.	P2	Not started
WEB-14	AI features (payer policy chatbot, CPT/Panel agent, denial agent)	Route any prompt carrying claim or patient data only to a BAA-covered Azure OpenAI deployment. Treat prompt and response logs as PHI.	P1	Not started
WEB-15	Admin screens	Restrict menu, role and user admin to an admin role, and audit every change.	P2	Not started

5. AR Workbench (LRN.ARWorkbench, React)

The browser is an untrusted place to hold PHI, so the priorities are token handling, leaving nothing behind after logout, and keeping PHI out of telemetry.

ID	Concern	Solution	Priority	Status
ARWB-01	Token storage	Use MSAL React with `cacheLocation: sessionStorage` or memory, never localStorage. A backend-for-frontend with HttpOnly cookies is the stronger option.	P1	Not started
ARWB-02	PHI persisted in the browser	Store no PHI in localStorage or IndexedDB, and don't persist Redux or React Query caches that hold claim or patient data.	P1	Not started
ARWB-03	Idle logout	Add a 15-minute idle timer with a warning. On logout, clear the store, query caches and session storage, and redirect.	P1	Not started
ARWB-04	PHI in routes	Use opaque IDs in routes (`/claims/8f3a...`), never names, MRNs or member IDs in paths or query strings.	P1	Not started
ARWB-05	Telemetry and trackers	Scrub PHI from App Insights, Sentry or any analytics before sending. Load no third-party tracker without a BAA on PHI screens.	P1	Not started
ARWB-06	Console and debug leakage	Strip `console.log` in production builds, disable Redux DevTools, and keep source maps off the public site.	P1	Not started

ID	Concern	Solution	Priority	Status
ARWB-07	Document viewing	Fetch a fresh short-lived SAS just before opening a document. Send no-store headers, and keep documents out of any service-worker cache.	P1	Not started
ARWB-08	Document upload UX	Validate type and size on the client too, show scan status, and block download until the malware scan passes.	P2	Not started
ARWB-09	UI-only permissions	Hide actions the user can't perform, and rely on API-03 and API-04 for real enforcement.	P2	Not started
ARWB-10	Content Security Policy	Set a CSP with no inline scripts, `connect-src` limited to ReportsApi, Entra and Blob, and `frame-ancestors 'none'`.	P2	Not started
ARWB-11	Dependency vulnerabilities	Run `npm audit` and Dependabot in CI, and fail the build on high or critical findings.	P2	Not started
ARWB-12	XSS	Avoid `dangerouslySetInnerHTML`. Sanitize any rich-text notes with DOMPurify.	P1	Not started
ARWB-13	Printing and screen exposure	Add a print stylesheet that masks identifiers, and a confidentiality banner on printed pages.	P3	Not started

6. Hosting: Azure VM, IIS, Docker and SQL MI

All three apps and six Windows services share one Windows Server 2022 VM, so a weakness on the host exposes every project at once.

ID	Concern	Solution	Priority	Status
HOST-01	Remote access to the VM	Close public RDP (3389). Use Azure Bastion or just-in-time VM access with MFA.	P1	Not started
HOST-02	Disk encryption	Turn on encryption at host or Azure Disk Encryption for the OS and data disks.	P1	Not started
HOST-03	OS patching	Use Azure Update Manager with a monthly patch window and record compliance.	P1	Not started
HOST-04	Network segmentation	Apply NSGs allowing only 443 inbound, and put SQL MI and Storage on private endpoints.	P2	Not started
HOST-05	Endpoint protection	Run Defender for Servers with EDR on the VM.	P2	Not started
HOST-06	Container images	Bake no secrets or PHI into images. Inject secrets at runtime from Key Vault.	P1	Not started
HOST-07	Image vulnerabilities	Pin patched Windows base images, rebuild monthly, and scan in ACR or Defender for Containers.	P2	Not started
HOST-08	Container and IIS logs	Strip query strings with PHI from IIS logs, ship container logs to Log Analytics, and apply the same retention.	P2	Not started
HOST-09	Windows services accounts	Run all six services under separate gMSAs with least privilege.	P2	Not started
HOST-10	Log Analytics workspace	Restrict access to reimbursement-agent-logs, set its retention, and confirm it falls under the BAA.	P2	Not started

ID	Concern	Solution	Priority	Status
HOST-11	Backups	Encrypt SQL MI backups with geo-redundancy, and test a restore every quarter.	P2	Not started

7. Rollout order and audit evidence

Work the P1 rows in these four waves. Each wave cuts the most risk for the least effort before the next one starts.

1. **Days 0–30, config fixes:**
   - SQL `Encrypt=True` (CC-08)
   - TLS and HSTS (CC-09)
   - Secrets fully moved to Key Vault (CC-10)
   - Close public RDP (HOST-01)
   - Swagger off (API-11)
   - Production error pages (API-09, WEB-12)
   - CORS locked down (API-10)
   - Strip PHI from logs (CC-18, MF-07)
2. **Days 0–45, identity:**
   - Entra ID with MFA (CC-11, WEB-01)
   - Session timeouts (WEB-02, ARWB-03)
   - Token storage (ARWB-01)
3. **Days 30–60, authorization and audit:**
   - Lab-scope filter (CC-15, API-04, WEB-05)
   - MasterFileProcessor lab guard (MF-05)
   - PhiAccessAudit table and middleware (CC-17, API-07)
   - Export controls (WEB-06, WEB-07)
4. **Days 45–90, storage and documents:**
   - Blob hardening (API-14 to API-19)
   - Temp file handling (MF-02, MF-03)
   - Snapshot lifecycle (MF-10)
5. **Days 60–180, P2 and P3:**

  - Managed identities and gMSA
  - Private endpoints
  - Defender scanning
  - Pen test
  - Policies and training

Evidence to keep for an audit:

- **Risk analysis:** the dated document and PHI data-flow map, with each annual refresh.
- **BAAs:** signed copies, plus an inventory of every vendor that touches PHI.
- **Configuration proof:** screenshots or exports for TDE, disk encryption, TLS settings, Conditional Access MFA policy, Key Vault access policies and Blob public-access settings.
- **Access reviews:** quarterly review sign-offs and deprovisioning records.
- **Audit logs:** samples of PhiAccessAudit and SQL Audit output, with the retention configuration.
- **Vulnerability management:** Defender scan reports, the pen test report and remediation tickets.
- **Contingency and response:** restore test results, the incident runbook and training completion records.

Sources

- MassiveGRID: HIPAA Security Rule update 2026, on the final-rule target date
- Linford & Co: HIPAA Security Rule requirements, on encryption moving from addressable to required
- Medcurity: HIPAA compliance, on the 240-day compliance window after a final rule